

TOP 10 MOST COMMON & IMPORTANT ATTACKS FOR SOC ANALYST

1 Phishing (Rank #1 – DAILY)

Why it matters:

 ~80–90% of incidents start with phishing

What SOC sees:

- User reports suspicious email
- Email gateway alert

SOC L1 Action:

- Check sender & URL
- Block domain
- Warn users

Interview line:

“Phishing is the most common initial access vector.”

2 Brute Force Login Attack

Why it matters:

 Constant alerts on VPN, AD, SSH, RDP

SOC Indicators:

- Multiple failed logins
- Same IP, many attempts

SOC Tools:

- SIEM
 - Windows Event ID 4625
-

3 Credential Stuffing

Why it matters:

👉 Happens after data breaches

SOC Indicators:

- Login from new country
- Successful login after failures

SOC L1 Action:

- Force password reset
 - Enable MFA
-

4 Malware Infection

Why it matters:

👉 Very common via email & downloads

SOC Alerts:

- Defender / EDR detection
- Suspicious process

SOC Action:

- Isolate endpoint
 - Collect hash
-

5 Ransomware (MOST CRITICAL)

Why it matters:

👉 High impact, business stopping

SOC Indicators:

- File encryption
- Strange extensions

SOC L1 Rule:

🚨 Immediate escalation

6 DDoS / Traffic Flooding

Why it matters:

👉 Public-facing servers are attacked

SOC Alerts:

- Traffic spike
- Firewall alerts

SOC L1 Action:

- Inform network team
 - Monitor impact
-

7 Unauthorized Access / Account Compromise

Why it matters:

👉 Leads to data breach

SOC Indicators:

- Login at odd hours
 - Admin login from new IP
-

8 Port Scanning / Reconnaissance

Why it matters:

👉 Early stage of attack

SOC Indicators:

- Sequential port hits

- Nmap detection

SOC Action:

- Block IP
 - Monitor follow-up activity
-

9 Privilege Escalation

Why it matters:

👉 Turns small incident into big breach

SOC Indicators:

- User becomes admin suddenly
-

10 Data Exfiltration

Why it matters:

👉 Final stage of attack

SOC Indicators:

- Large uploads
- DNS tunneling



BRUTE FORCE ATTACK – COMPLETE SOC L1 INTERVIEW GUIDE

1 What is a Brute Force Attack?

A **brute force attack** is an authentication-based attack where an attacker **tries multiple username and password combinations repeatedly** until access is gained.

It is usually **automated** and targets exposed authentication services.

SOC View:

Any **abnormal authentication behavior** that exceeds normal login attempts is treated as a potential brute force.

2 Why Brute Force Attacks Matter in SOC?

Because:

- They are **very common**
 - They are often the **first stage of larger attacks**
 - If successful, they lead to:
 - Account compromise
 - Privilege escalation
 - Data breaches
 - Malware deployment
-

3 Common Services Targeted

Service	Port	Why
SSH	22	Remote Linux access
RDP	3389	Windows remote access
VPN	443	Corporate access
Web Login	80/443	Public-facing
Email (O365)	443	High-value accounts

4 Types of Brute Force Attacks (Interview MUST)

♦ 1. Classic Brute Force

- Tries all possible password combinations
 - Very noisy
 - Easy to detect
-

♦ 2. Dictionary Attack

- Uses common password lists
 - Faster than full brute force
-

♦ 3. Credential Stuffing

- Uses leaked credentials from past breaches
- Very effective
- Common in cloud/email attacks

◆ 4. Password Spraying (VERY IMPORTANT)

- One password → many users
 - Low and slow
 - Harder to detect
 - Very common in enterprise attacks
-

5 Real SOC Scenario (Interview Gold)

Scenario:

SIEM generates an alert:

“50 failed login attempts detected for multiple users from IP 185.220.x.x in 10 minutes.”

SOC L1 Thinking:

- External IP
 - Multiple users
 - Short timeframe
- ➡ Possible brute force / password spraying
-

6 Indicators of Brute Force (IOCs)

SOC L1 watches for:

- High failed login count
- Same IP targeting many users

- One user targeted by many IPs
 - Login attempts outside business hours
 - Sudden account lockouts
 - Failed → successful login pattern
-

7 Logs SOC L1 Must Check

♦ Authentication Logs

- Windows Event Logs (4625, 4624)
- Linux `/var/log/auth.log`
- AD logs
- VPN logs

♦ Network Logs

- Firewall
- IDS/IPS
- WAF

♦ Cloud Logs

- Azure AD sign-ins
 - O365 audit logs
-

8 SOC L1 Detection in SIEM (Conceptual)

SOC L1 looks for:

- Failed logins > threshold

- Same IP or same user
- Short time window

Example logic:

“More than 10 failed logins in 5 minutes”

9 SOC L1 Response – Step by Step

● Step 1: Alert Triage

- Identify:
 - Source IP
 - Target account(s)
 - Login service
 - Timeframe
-

● Step 2: Validation

Check:

- Is IP internal or external?
- Is user expected to login?
- Is it business hours?

Use:

- VirusTotal
 - AbuseIPDB
 - Cisco Talos
-

Step 3: Containment

- Temporarily disable account (if policy allows)
 - Block IP at firewall
 - Force password reset
-

Step 4: Scope Analysis

Check:

- Other users targeted?
 - Other services attacked?
 - Any successful login?
-

Step 5: Escalation

Escalate to SOC L2 if:

- Login successful
 - Admin account targeted
 - Lateral movement suspected
-

If Brute Force is Successful – Risks

- Unauthorized system access
- Data theft
- Privilege escalation
- Malware installation
- Persistence mechanisms

11 Post-Incident Actions

- Reset passwords
 - Enable MFA
 - Endpoint scan
 - Monitor affected user activity
 - Update detection rules
-

12 Prevention Measures (Interview Favorite)

Authentication

- Strong passwords
- MFA
- Account lockout policy

Network

- Geo-blocking
- IP reputation filtering
- Rate limiting

User Awareness

- Password hygiene training
 - Avoid password reuse
-

13 Documentation (SOC L1 Responsibility)

SOC L1 documents:

- Timeline
 - IPs
 - Accounts affected
 - Tools used
 - Actions taken
 - Escalation notes
-

14 Brute Force vs Password Spraying (Asked Often)

Brute Force

One user

Many passwords

Noisy

Easier to detect

Password Spraying

Many users

One password

Stealthy

Harder

15 Common SOC L1 Interview Questions & Answers

Q1. How do you identify a brute force attack?

Answer:

By observing repeated failed authentication attempts from the same IP or targeting multiple users within a short time period.

Q2. What logs do you analyze?

Answer:

Authentication logs, firewall logs, VPN logs, and SIEM correlation alerts.

Q3. How do you differentiate false positives?

Answer:

By checking IP reputation, business hours, user behavior, and login source legitimacy.

Q4. When do you escalate?

Answer:

If login succeeds, privileged accounts are involved, or post-authentication activity is suspicious.

Q5. How do you prevent brute force attacks?

Answer:

MFA, account lockout policies, strong passwords, and monitoring.

** Interview Closing Statement (Use This)**

“As a SOC L1 analyst, my role is to quickly detect brute force attempts, validate alerts, contain the threat, document findings, and escalate when necessary to minimize impact.”

Phishing Attack – COMPLETE SOC L1 INTERVIEW GUIDE

What is a Phishing Attack?

A **phishing attack** is a social engineering attack where an attacker sends a **fake email, message, or website** to trick users into:

- Revealing credentials
- Clicking malicious links
- Downloading malware
- Providing sensitive data

 It **targets human psychology**, not system vulnerabilities.

 **SOC View:**

Any **suspicious email activity, fake login pages, malicious links, or abnormal email behavior** is treated as a potential phishing incident.

Why Phishing Attacks Matter in SOC?

Because:

- ✓ #1 Initial Access Vector (Most Common Attack Entry)
- ✓ Leads to credential theft

- ✓ Causes ransomware attacks
- ✓ Enables Business Email Compromise (BEC)

If successful, it can lead to:

- Account takeover
 - Data breaches
 - Financial fraud
 - Malware infection
 - Lateral movement
-

3 Common Phishing Targets

Target	Why Attackers Target
Corporate Email	Access to company data
O365 / Google	Cloud access
Banking Users	Financial theft
HR/Finance Teams	Invoice fraud
Executives	High privilege access

4 Types of Phishing Attacks (INTERVIEW MUST)

◆ 1. Email Phishing (Most Common)

Mass emails sent to many users.

Example:

“Your account will be suspended. Click here.”

SOC Note:

Usually contains malicious links or attachments.

◆ 2. Spear Phishing

Targeted attack on specific person.

Example:

Fake email pretending to be from HR to one employee.

More dangerous because:

- Personalized
 - Hard to detect
-

◆ 3. Whaling

Targets executives or high-level employees.

Example:

Fake CEO email asking finance to transfer money.

Very high impact attack.

◆ 4. Smishing

Phishing via SMS messages.

Example:

“Your bank account is locked. Click link.”

◆ 5. Vishing

Phishing via phone calls.

Attacker pretends to be IT support or bank.

5 Real SOC Scenario (INTERVIEW GOLD)

Scenario:

User reports an email:

“You received a secure document. Login to view.”

Email contains a link to:

micros0ft-login-secure.com

🧠 SOC L1 Thinking:

- Suspicious domain
- Looks like Microsoft

- User asked to login
 - ➡ Possible phishing attempt
-

6 Indicators of Phishing (IOCs)

SOC L1 watches for:

Email Indicators

- Spoofed sender address
 - Suspicious attachments
 - Urgent language (“Act now!”)
 - Misspelled domains
 - Fake login links
-

Technical Indicators

- Newly registered domains
 - URL redirection
 - Mismatch between display name & email
 - External sender pretending internal
-

7 Logs SOC L1 Must Check

◆ Email Security Logs

- Secure Email Gateway (SEG)
 - O365 Message Trace
 - Email headers
-

◆ Authentication Logs

- Azure AD Sign-ins
 - Failed/suspicious logins
-

◆ Endpoint Logs

- EDR alerts
 - File download logs
-

◆ Network Logs

- Proxy logs
 - DNS logs
-

8 SOC L1 Detection in SIEM(Conceptual)

SOC looks for:

- Multiple users receiving same suspicious email
- Emails from known malicious domains
- Users clicking malicious links
- Login attempts after phishing email

Example Rule:

“Email contains suspicious domain + user login from new location”

9 SOC L1 Response – Step by Step

Step 1: Alert Triage

Identify:

- Sender email
 - Subject line
 - Target users
 - Attachment/link
-

Step 2: Validation

Check:

- Email header analysis
- Domain reputation

- URL sandbox results

Tools:

- VirusTotal
 - URLScan
 - Talos Intelligence
 - PhishTool
-

Step 3: Containment

Actions:

- Quarantine email
 - Block malicious domain
 - Reset affected account password
-

Step 4: Scope Analysis

Check:

- How many users received?
 - Who clicked?
 - Any credential compromise?
 - Malware downloaded?
-

Step 5: Escalation

Escalate if:

- Credentials stolen
 - Malware executed
 - Privileged account affected
-

If Phishing is Successful – Risks

- Account takeover
 - Data theft
 - Financial fraud
 - Ransomware infection
 - Persistence access
-

Post-Incident Actions

- Force password reset
 - Enable MFA
 - Scan affected endpoints
 - Block malicious domains
 - Monitor login activity
-

Prevention Measures (INTERVIEW FAVORITE)

Authentication Security

- MFA
 - Conditional access
 - Login alerts
-

Email Security

- Anti-phishing filters
 - Email sandboxing
 - DMARC / SPF / DKIM
-

User Awareness

- Phishing training
 - Report suspicious emails
 - Avoid clicking unknown links
-

Documentation (SOC L1 Responsibility)

SOC L1 must document:

- Timeline
- Malicious URLs/domains
- Impacted users

- Actions taken
 - Escalation details
-

14 Phishing vs Malware Email (COMMON INTERVIEW QUESTION)

Phishing

Steals credentials

Fake login page

Social engineering

Malware Email

Installs malware

Malicious attachment

Technical exploit

15 Common SOC L1 Interview Questions & Answers

Q1. How do you identify phishing emails?

Answer:

By analyzing suspicious sender addresses, malicious links, urgent language, and mismatched domains.

Q2. What logs do you analyze?

Answer:

Email gateway logs, authentication logs, proxy logs, and SIEM alerts.

Q3. What is your first action?

Answer:

Triage the alert, analyze email headers, and check domain reputation.

Q4. When do you escalate?

Answer:

When credentials are compromised, malware executed, or high-privilege users are affected.

Q5. How do you prevent phishing attacks?

Answer:

MFA, email filtering, user awareness training, and domain protection controls.

Interview Closing Statement (USE THIS)

 **Best Answer:**

“As a SOC L1 analyst, my responsibility is to quickly identify phishing attempts, analyze email indicators, contain malicious content, protect user accounts, document findings, and escalate incidents when necessary.”

How to Study This for Interview

- ✓ Memorize attack flow
 - ✓ Practice explaining one real phishing scenario
 - ✓ Use SOC keywords:
 - Triage
 - IOC analysis
 - Containment
 - Remediation
 - Escalation
-

MALWARE ATTACK – COMPLETE SOC L1 INTERVIEW GUIDE

What is Malware?

Malware = Malicious Software

It is any software designed to:

- Damage systems
- Steal data
- Gain unauthorized access
- Disrupt operations

Examples:

Virus, Trojan, Ransomware, Spyware, Worm.

SOC View:

Any **suspicious file execution, unusual system behavior, or malicious network activity** is treated as a possible malware incident.

2 Why Malware Attacks Matter in SOC?

Because malware can:

- ✓ Provide attackers initial access
- ✓ Steal sensitive data
- ✓ Install backdoors
- ✓ Spread across network
- ✓ Deploy ransomware

👉 Malware is one of the **top SOC incidents worldwide**.

3 Common Malware Entry Points

Entry Method	Example
Phishing Email	Malicious attachment
Drive-by Download	Visiting infected website
USB Devices	Infected removable media
Exploiting Vulnerabilities	Unpatched systems
Pirated Software	Trojanized installers

4 Types of Malware (INTERVIEW MUST)

◆ 1. Virus

Attaches to legitimate files and spreads when executed.

Example:

Infected .exe file spreads to other files.

◆ 2. Worm

Self-replicates across networks automatically.

Example:

WannaCry worm spreading via SMB.

◆ 3. Trojan

Disguised as legitimate software.

Example:

Fake cracked software installs backdoor.

◆ 4. Ransomware (VERY IMPORTANT)

Encrypts files and demands ransom.

Example:

LockBit, WannaCry.

◆ 5. Spyware

Secretly collects user data.

Example:

Keyloggers stealing passwords.

◆ 6. Adware

Displays unwanted advertisements.

Usually low severity but still malicious.

5 Real SOC Scenario (INTERVIEW GOLD)

Scenario:

User downloads attachment:

`Invoice_2024.zip`

After opening:

- System becomes slow
 - Unknown process running
 - Multiple outbound connections detected
-

SOC L1 Thinking:

- Suspicious file execution
 - Abnormal network traffic
 - ➡ Possible malware infection
-

6 Indicators of Malware (IOCs)

SOC L1 watches for:



Host Indicators

- Unknown processes
- High CPU usage
- Suspicious startup entries
- Disabled antivirus
- New registry changes

Network Indicators

- Connections to malicious IPs
 - Data exfiltration traffic
 - Command & Control (C2) communication
-

File Indicators

- Suspicious file hashes
 - Unknown executables
 - Hidden files
-

Logs SOC L1 Must Check

◆ **Endpoint Logs**

- EDR alerts
 - Windows Event Logs
 - Process creation logs
-

◆ **Network Logs**

- Firewall logs
 - IDS/IPS alerts
 - Proxy logs
-

◆ Email Logs

If malware came via phishing.

8 SOC L1 Detection in SIEM

SOC L1 looks for:

- Suspicious process execution
- Known malware hash matches
- Connection to malicious domains
- Multiple alerts from same endpoint

Example Rule:

“Process executed + outbound connection to known C2 IP”

9 SOC L1 Response – Step by Step

● Step 1: Alert Triage

Identify:

- Affected system
 - Malware type (if known)
 - Detection source (EDR/SIEM)
-

Step 2: Validation

Check:

- File hash reputation
- Process behavior
- Network connections

Tools:

- VirusTotal
 - Hybrid Analysis
 - Any.Run
 - Talos Intelligence
-

Step 3: Containment

Immediate actions:

- Isolate infected system
 - Block malicious IP/domain
 - Stop malicious process
-

Step 4: Scope Analysis

Check:

- Other infected systems?
 - Malware spread?
 - Data exfiltration?
-

Step 5: Escalation

Escalate if:

- Ransomware detected
 - Multiple systems infected
 - Sensitive data involved
-

10 If Malware is Successful – Risks

- Data theft
 - System compromise
 - Ransomware encryption
 - Network propagation
 - Persistence backdoors
-

11 Post-Incident Actions

- Remove malware
 - Patch vulnerabilities
 - Reset passwords
 - Perform full system scan
 - Monitor system activity
-

Prevention Measures

Endpoint Security

- EDR solutions
 - Antivirus updates
 - Application whitelisting
-

Network Security

- Firewall rules
 - IDS/IPS
 - Web filtering
-

User Awareness

- Avoid suspicious downloads
- Do not open unknown attachments

13 Documentation (SOC L1 Responsibility)

SOC L1 must record:

- Malware name/hash
 - Affected systems
 - Timeline
 - Actions taken
 - Escalation notes
-

14 Malware vs Virus vs Trojan

Malware	Virus	Trojan
Generic term	Infects files	Disguised software
Includes all types	Needs user action	Creates backdoor

15 Common SOC L1 Interview Questions & Answers

Q1. How do you detect malware?

Answer:

By monitoring suspicious processes, file hashes, abnormal network connections, and EDR alerts.

Q2. What logs do you analyze?

Answer:

Endpoint logs, EDR alerts, firewall logs, and SIEM correlation alerts.

Q3. What is your first action?

Answer:

Triage the alert, validate infection, and isolate the affected system.

Q4. When do you escalate?

Answer:

When malware spreads, ransomware is detected, or critical systems are affected.

Q5. How do you prevent malware attacks?

Answer:

EDR protection, patch management, email filtering, and user awareness training.

Interview Closing Statement

Best Answer:

“As a SOC L1 analyst, my role is to quickly detect malware activity, analyze indicators, isolate infected systems, contain the threat, document findings, and escalate when required to prevent further damage.”

How to Study This for Interview

-  Understand malware lifecycle
-  Practice explaining one infection scenario
-  Use SOC keywords:

- IOC analysis
 - Containment
 - Isolation
 - Remediation
 - Escalation
-

RANSOMWARE ATTACK – COMPLETE SOC L1 INTERVIEW GUIDE

What is Ransomware?

Ransomware is a type of malware that:

👉 **Encrypts files or locks systems**

👉 **Demands payment (ransom) to restore access**

Usually payment is demanded in **cryptocurrency (Bitcoin)**.

🧠 **SOC View:**

Any signs of **mass file encryption, ransom notes, abnormal file changes, or suspicious process behavior** are treated as ransomware incidents.

2 Why Ransomware Matters in SOC?

Because it is:

💣 One of the **most dangerous cyber attacks**

💣 Causes business downtime

💣 Leads to data loss & financial damage

If successful, it can result in:

- Complete system shutdown
 - Data theft
 - Legal penalties
 - Reputation damage
-

3 Common Ransomware Entry Points

Entry Method

Example

Phishing Email	Malicious attachment
RDP Brute Force	Weak passwords exploited
Software Vulnerabilities	Unpatched systems
Malicious Downloads	Fake software
Insider Actions	Intentional infection

4 Types of Ransomware (INTERVIEW MUST)

♦ 1. Crypto Ransomware (Most Common)

Encrypts files and demands payment.

Example:

WannaCry, LockBit.

♦ 2. Locker Ransomware

Locks system access completely.

User cannot log into system.

♦ 3. Double Extortion Ransomware (VERY IMPORTANT)

Modern ransomware:

- ① Encrypts files
- ② Steals data
- ③ Threatens to leak data

Most common today.

♦ 4. RaaS (Ransomware as a Service)

Attackers rent ransomware tools on dark web.

Very popular in modern attacks.

⑤ Real SOC Scenario (INTERVIEW GOLD)

Scenario:

User reports:

- Files renamed with `.locked` extension
- Ransom note file appears
- System becomes very slow

EDR alert shows:

“Mass file modification detected”

SOC L1 Thinking:

- Multiple file changes

- Encryption activity
 - ➔ Possible ransomware infection
-

6 Indicators of Ransomware (IOCs)

SOC L1 watches for:

Host Indicators

- Files renamed with strange extensions
 - Ransom note files (README.txt)
 - High disk activity
 - Unknown encryption processes
-

Network Indicators

- Connection to C2 servers
 - Data exfiltration traffic
-

Behavioral Indicators

- Mass file modifications
 - Shadow copy deletion
 - Disabled antivirus
-

7 Logs SOC L1 Must Check

◆ Endpoint Logs

- EDR alerts
 - Windows Event Logs
 - Process creation logs
-

◆ Network Logs

- Firewall logs
 - IDS/IPS alerts
-

◆ Authentication Logs

To identify initial access (RDP brute force).

8 SOC L1 Detection in SIEM (Conceptual)

SOC L1 looks for:

- Rapid file changes
- Suspicious process activity
- Ransomware signatures
- Shadow copy deletion commands

Example Rule:

“Multiple file modifications + suspicious process execution”

9 SOC L1 Response – Step by Step

Step 1: Alert Triage

Identify:

- Affected system
 - Ransomware indicators
 - Detection source
-

Step 2: Validation

Check:

- File encryption activity
 - Ransom note presence
 - EDR behavior logs
-

Step 3: Containment (MOST IMPORTANT)

Immediate actions:

-  Isolate infected system from network
-  Disable shared drives access
-  Block malicious IPs

● Step 4: Scope Analysis

Check:

- Other infected machines?
- Lateral movement?
- Data exfiltration?

● Step 5: Escalation

Always escalate ransomware to:

SOC L2 / Incident Response Team.

Because ransomware = **Critical Severity Incident**

10 If Ransomware is Successful – Risks

- Data loss
- Business downtime
- Financial damage
- Legal penalties
- Data leakage

11 Post-Incident Actions

- Restore from backups
 - Remove malware
 - Reset passwords
 - Patch vulnerabilities
 - Monitor network
-

Prevention Measures (INTERVIEW FAVORITE)

Endpoint Security

- EDR with ransomware protection
 - Regular patching
 - Disable macros
-

Network Security

- Network segmentation
 - Block RDP exposure
 - IDS/IPS monitoring
-

Backup Strategy (VERY IMPORTANT)

- Regular offline backups
 - Test backup recovery
-

User Awareness

- Avoid suspicious attachments
 - Report phishing emails
-

Documentation (SOC L1 Responsibility)

SOC L1 must record:

- Timeline
 - Affected systems
 - Ransomware indicators
 - Actions taken
 - Escalation details
-

Ransomware vs Malware (COMMON INTERVIEW)

Malware	Ransomware
General term	Specific type
Many purposes	Encrypts files
May be silent	Very visible

Common SOC L1 Interview Questions & Answers

Q1. How do you identify ransomware?

Answer:

By detecting mass file encryption, ransom notes, abnormal file extensions, and EDR alerts.

Q2. What is your first action?

Answer:

Immediately isolate the infected system to stop spread.

Q3. Why is isolation critical?

Answer:

Because ransomware spreads quickly across network shares.

Q4. What logs do you check?

Answer:

EDR logs, process logs, file activity logs, and network traffic logs.

Q5. How do you prevent ransomware?

Answer:

Strong backups, EDR protection, patching, MFA, and user awareness training.

Interview Closing Statement (USE THIS)

Best Answer:

“As a SOC L1 analyst, my primary role during ransomware incidents is rapid detection, immediate system isolation, analyzing indicators, documenting findings, and escalating to incident response teams to minimize damage.”

How to Study This for Interview

-  Understand ransomware lifecycle
-  Remember “ISOLATE FIRST” rule
-  Practice explaining one real scenario

Use SOC keywords:

- Containment
 - Isolation
 - Encryption activity
 - Lateral movement
 - Critical severity incident
-

DDoS ATTACK – COMPLETE SOC L1 INTERVIEW GUIDE

1 What is a DDoS Attack?

DDoS = Distributed Denial of Service

It is an attack where **multiple compromised systems (bots)** flood a target server/network with huge traffic to:

- 👉 Make it slow
 - 👉 Crash services
 - 👉 Make website unavailable
-

🧠 SOC View:

Any **sudden abnormal traffic spike, service unavailability, or network congestion** is treated as a potential DDoS incident.

2 Why DDoS Attacks Matter in SOC?

Because they:

- 🚨 Disrupt business operations
- 🚨 Cause downtime
- 🚨 Affect customer trust
- 🚨 Can hide other attacks

If successful, it leads to:

- Website/service outage
- Revenue loss
- Network congestion
- Resource exhaustion

③ Common DDoS Targets

Target	Why Attackers Target
Web Servers	Public-facing services
Banking Systems	Financial disruption
E-commerce Sites	Revenue impact
DNS Servers	Internet disruption
VPN Gateways	Block remote access

④ Types of DDoS Attacks (INTERVIEW MUST)

◆ 1. Volume-Based Attacks (Most Common)

Flood network with massive traffic.

Example:

UDP flood, ICMP flood.

Goal:

Consume bandwidth.

◆ 2. Protocol Attacks

Exploit network protocol weaknesses.

Example:

SYN Flood.

Goal:

Exhaust server resources.

◆ 3. Application Layer Attacks (VERY IMPORTANT)

Target specific applications.

Example:

HTTP GET Flood.

Goal:

Overload web server.

Hardest to detect.

⑤ Real SOC Scenario (INTERVIEW GOLD)

Scenario:

SIEM alert shows:

- Website response time increased
 - Sudden traffic spike
 - Thousands of requests from multiple IPs
-



SOC L1 Thinking:

- Traffic from many sources
 - High request rate
-  Possible DDoS attack
-

6 Indicators of DDoS (IOCs)

SOC L1 watches for:

Network Indicators

- Sudden traffic spikes
 - Thousands of connections
 - Traffic from many IPs
 - Unusual geographic sources
-

System Indicators

- Server CPU high
 - Memory exhaustion
 - Service crashes
-

Behavioral Indicators

- Repeated same requests
- Abnormal traffic patterns

7 Logs SOC L1 Must Check

◆ Network Logs

- Firewall logs
 - Router logs
 - NetFlow logs
-

◆ Web Server Logs

- HTTP request logs
 - Access logs
-

◆ IDS/IPS Logs

For flood attack detection.

8 SOC L1 Detection in SIEM (Conceptual)

SOC L1 looks for:

- Traffic volume threshold exceeded
- Multiple connection attempts

- Abnormal request rates

Example Rule:

“Connections exceed 10,000 per minute from multiple IPs”

9 SOC L1 Response – Step by Step

Step 1: Alert Triage

Identify:

- Target system
 - Traffic type
 - Timeframe
-

Step 2: Validation

Check:

- Traffic patterns
 - IP distribution
 - False positives (like marketing campaigns)
-

Step 3: Containment

Actions:

- Block malicious IPs
 - Enable rate limiting
 - Activate DDoS protection
-

Step 4: Scope Analysis

Check:

- Other systems affected?
 - Attack duration?
 - Traffic sources?
-

Step 5: Escalation

Escalate if:

- Service outage occurs
 - Attack volume is very high
 - Critical systems affected
-

10 If DDoS is Successful – Risks

- Service downtime
 - Financial loss
 - Reputation damage
 - Network congestion
-

Post-Incident Actions

- Traffic analysis
 - Improve mitigation rules
 - Update firewall configurations
 - Review network capacity
-

Prevention Measures (INTERVIEW FAVORITE)

Network Protection

- DDoS protection services (Cloudflare, Akamai)
 - Load balancing
 - Rate limiting
-

Infrastructure Security

- Network redundancy
 - Traffic filtering
 - Geo-blocking
-

Monitoring

- Real-time traffic monitoring
- SIEM alerts

13 Documentation (SOC L1 Responsibility)

SOC L1 records:

- Timeline
 - Target systems
 - Traffic patterns
 - Mitigation actions
 - Escalation details
-

14 DoS vs DDoS (COMMON INTERVIEW)

DoS

Single attacker

Easier to stop

Less traffic

DDoS

Multiple attackers

Hard to mitigate

Massive traffic

15 Common SOC L1 Interview Questions & Answers

Q1. How do you detect a DDoS attack?

Answer:

By monitoring abnormal traffic spikes, multiple connection attempts, and service unavailability.

Q2. What logs do you analyze?

Answer:

Firewall logs, NetFlow logs, web server logs, and IDS alerts.

Q3. What is your first action?

Answer:

Triage the alert, validate traffic patterns, and initiate containment measures like rate limiting.

Q4. When do you escalate?

Answer:

When critical services are down or attack volume exceeds mitigation capability.

Q5. How do you prevent DDoS attacks?

Answer:

Using DDoS protection services, rate limiting, traffic filtering, and load balancing.

 Interview Closing Statement (USE THIS)

✓ **Best Answer:**

“As a SOC L1 analyst, my role in a DDoS incident is to quickly identify abnormal traffic patterns, validate alerts, initiate containment measures, monitor service impact, and escalate to network or SOC L2 teams when necessary.”

📌 **How to Study This for Interview**

- ✓ Understand DDoS attack types
- ✓ Practice explaining one real scenario
- ✓ Remember traffic-based detection

Use SOC keywords:

- Traffic spike
 - Bandwidth exhaustion
 - Rate limiting
 - Mitigation
 - Escalation
-

🔒 **DATA EXFILTRATION – COMPLETE SOC L1
INTERVIEW GUIDE**

1 What is Data Exfiltration?

Data Exfiltration is a cyber attack where an attacker:

- 👉 Steals sensitive data from an organization
- 👉 Transfers it outside the network without authorization

This is also called:

- Data theft
 - Data leakage
 - Information exfiltration
-

🧠 SOC View:

Any **unauthorized data transfer, abnormal outbound traffic, or suspicious file access** is treated as possible data exfiltration.

2 Why Data Exfiltration Matters in SOC?

Because it can lead to:

- 🚨 Loss of sensitive data
- 🚨 Financial damage
- 🚨 Legal penalties
- 🚨 Reputation loss

Data stolen may include:

- Customer data
 - Financial records
 - Credentials
 - Intellectual property
-

3 Common Data Exfiltration Methods

Method	Example
Email	Sending sensitive files externally
Cloud Upload	Uploading to Google Drive/Dropbox
USB Devices	Copying to removable media
Malware	Stealing data via C2 server
Web Traffic	Hidden data transfer via HTTP/DNS

4 Types of Data Exfiltration (INTERVIEW MUST)

♦ 1. Insider Exfiltration

Employee intentionally steals data.

Example:

Copying company files to USB.

♦ 2. Malware-Based Exfiltration

Malware secretly sends data to attacker.

Example:

Spyware sending credentials to C2 server.

♦ 3. Command & Control (C2) Exfiltration

Attackers remotely control system and extract data.

Very common in APT attacks.

♦ 4. DNS Tunneling (VERY IMPORTANT)

Data hidden inside DNS traffic.

Hard to detect.

♦ 5. Cloud-Based Exfiltration

Data uploaded to personal cloud storage.

5 Real SOC Scenario (INTERVIEW GOLD)

Scenario:

SIEM alert shows:

- Large outbound traffic from a user system
 - Data uploaded to unknown external server
 - Activity during non-business hours
-

SOC L1 Thinking:

- Unusual data transfer
 - External destination
-  Possible data exfiltration
-

6 Indicators of Data Exfiltration (IOCs)

SOC L1 watches for:

Network Indicators

- Large outbound traffic spikes
 - Data sent to unknown IPs
 - Repeated DNS queries
 - Encrypted traffic to suspicious domains
-

Host Indicators

- Access to sensitive files
 - Large file compression activity
 - USB device usage
-

Behavioral Indicators

- Activity outside business hours
 - Unusual user behavior
-

7 Logs SOC L1 Must Check

◆ Network Logs

- Firewall logs
 - Proxy logs
 - NetFlow logs
-

◆ Endpoint Logs

- File access logs
 - USB usage logs
 - EDR alerts
-

◆ Cloud Logs

- O365 activity logs
 - Google Workspace logs
-

8 SOC L1 Detection in SIEM (Conceptual)

SOC L1 looks for:

- Large outbound data transfer
- Suspicious DNS traffic
- File access anomalies

Example Rule:

“Outbound traffic exceeds normal baseline to unknown IP”

9 SOC L1 Response – Step by Step

Step 1: Alert Triage

Identify:

- Affected system
 - Data transfer volume
 - Destination IP/domain
-

Step 2: Validation

Check:

- Is traffic legitimate?
 - User activity pattern
 - Destination reputation
-

Step 3: Containment

Actions:

- Block malicious IP/domain

- Disable affected account
 - Isolate system if needed
-

Step 4: Scope Analysis

Check:

- What data was stolen?
 - How long attack occurred?
 - Other affected systems?
-

Step 5: Escalation

Escalate if:

- Sensitive data involved
 - Insider threat suspected
 - Large data loss
-

10 If Data Exfiltration is Successful – Risks

- Data breach
 - Financial loss
 - Regulatory penalties
 - Reputation damage
-

Post-Incident Actions

- Reset credentials
 - Review access controls
 - Monitor user activity
 - Strengthen DLP policies
-

Prevention Measures (INTERVIEW FAVORITE)



Data Protection

- Data Loss Prevention (DLP)
 - Encryption
 - Access control policies
-



Network Security

- Traffic monitoring
 - Blocking suspicious domains
 - IDS/IPS alerts
-



User Awareness

- Prevent insider threats
- Secure data handling training

13 Documentation (SOC L1 Responsibility)

SOC L1 records:

- Timeline
 - Affected systems
 - Data type stolen
 - Destination IPs
 - Actions taken
-

14 Data Exfiltration vs Data Leak (COMMON INTERVIEW)

Data Exfiltration

Intentional theft

Malicious activity

Data Leak

Accidental exposure

Misconfiguration

15 Common SOC L1 Interview Questions & Answers

Q1. How do you detect data exfiltration?

Answer:

By monitoring abnormal outbound traffic, large data transfers, suspicious file access, and unusual user behavior.

Q2. What logs do you analyze?

Answer:

Firewall logs, proxy logs, file access logs, and cloud activity logs.

Q3. What is your first action?

Answer:

Triage the alert, validate data transfer legitimacy, and block suspicious destinations.

Q4. When do you escalate?

Answer:

When sensitive data is stolen, insider threat is suspected, or large-scale data transfer occurs.

Q5. How do you prevent data exfiltration?

Answer:

Using DLP solutions, access controls, encryption, and network monitoring.

 Interview Closing Statement (USE THIS)

✓ **Best Answer:**

“As a SOC L1 analyst, my role in data exfiltration incidents is to detect abnormal outbound activity, validate alerts, contain unauthorized data transfers, document findings, and escalate when sensitive data is at risk.”

 How to Study This for Interview

- ✓ Understand exfiltration methods
- ✓ Remember “Outbound traffic monitoring”
- ✓ Practice one scenario explanation

Use SOC keywords:

- DLP
 - Outbound traffic
 - Data transfer anomaly
 - Containment
 - Escalation
-

 **INSIDER THREAT – COMPLETE SOC L1
INTERVIEW GUIDE**

1 What is an Insider Threat?

An **Insider Threat** is a security risk that comes from:

- 👉 People **inside the organization** who have legitimate access
- 👉 Such as employees, contractors, or partners

They may:

- Misuse access intentionally
 - Accidentally cause damage
 - Have compromised accounts
-

🧠 SOC View:

Any **suspicious activity from legitimate internal users**, like abnormal data access, privilege misuse, or unusual behavior, is treated as a potential insider threat.

2 Why Insider Threats Matter in SOC?

Because insiders:

- 🔴 Already have system access
- 🔴 Know internal processes
- 🔴 Can bypass many security controls

If successful, they can cause:

- Data theft
 - Financial fraud
 - System sabotage
 - Compliance violations
-

③ Types of Insider Threats (INTERVIEW MUST)

◆ 1. Malicious Insider (Most Dangerous)

Employee intentionally steals or damages data.

Example:

Copying confidential files before resigning.

◆ 2. Negligent Insider

Employee unintentionally causes security incident.

Example:

Sending sensitive file to wrong email.

Most common type.

◆ 3. Compromised Insider

Employee account hacked by attacker.

Example:

Phishing leads to stolen credentials.

Very common in SOC alerts.

4 Common Insider Threat Activities

Activity	Risk
Copying data to USB	Data theft
Accessing files outside job role	Privilege misuse
Logging in at unusual times	Suspicious behavior
Uploading data to cloud	Exfiltration
Disabling security tools	Sabotage

5 Real SOC Scenario (INTERVIEW GOLD)

Scenario:

SIEM alert shows:

- Employee downloads large number of sensitive files
 - Access occurs at midnight
 - Data uploaded to personal cloud account
-

SOC L1 Thinking:

- Unusual behavior
 - High data access
-  Possible insider threat
-

6 Indicators of Insider Threat (IOCs)

SOC L1 watches for:



User Behavior Indicators

- Access outside business hours
 - Login from unusual location
 - Excessive file downloads
-



Data Access Indicators

- Access to sensitive files
 - Copying large data volumes
 - Unauthorized privilege usage
-



Network Indicators

- Uploading data externally
 - Use of unauthorized cloud storage
-

7 Logs SOC L1 Must Check

◆ Authentication Logs

- Login time/location
 - Failed login attempts
-

◆ **File Access Logs**

- File server logs
 - SharePoint/O365 logs
-

◆ **Endpoint Logs**

- USB usage logs
 - EDR alerts
-

◆ **Cloud Logs**

- Data uploads
 - External sharing activity
-

8 SOC L1 Detection in SIEM (Conceptual)

SOC L1 looks for:

- Abnormal user behavior
- Large data access patterns
- Privilege misuse alerts

Example Rule:

“User downloads >100 sensitive files within 1 hour”

9 SOC L1 Response – Step by Step

Step 1: Alert Triage

Identify:

- User account
 - Activity type
 - Data accessed
-

Step 2: Validation

Check:

- Is activity legitimate?
 - User role & job function
 - Business hours
-

Step 3: Containment

Actions:

- Disable account (if policy allows)
 - Block external data transfer
 - Isolate affected system
-

Step 4: Scope Analysis

Check:

- What data was accessed?
 - How much data involved?
 - Other suspicious activities?
-

Step 5: Escalation

Escalate if:

- Sensitive data involved
 - Malicious intent suspected
 - Compliance risk exists
-

If Insider Threat is Successful – Risks

- Data breaches
 - Financial losses
 - Regulatory violations
 - Reputation damage
-

Post-Incident Actions

- Review access permissions
 - Reset credentials
 - Strengthen monitoring
 - Conduct HR/security investigation
-

Prevention Measures (INTERVIEW FAVORITE)



Access Control

- Least privilege principle
 - Role-based access control
-



Monitoring

- User Behavior Analytics (UBA)
 - SIEM monitoring
-



Data Protection

- DLP solutions
 - Encryption
-

Employee Awareness

- Security training
 - Acceptable use policies
-

Documentation (SOC L1 Responsibility)

SOC L1 records:

- Timeline
 - User account involved
 - Data accessed
 - Actions taken
 - Escalation notes
-

Insider Threat vs External Threat (COMMON INTERVIEW)

Insider Threat	External Threat
-----------------------	------------------------

Inside organization	Outside attacker
---------------------	------------------

Has legitimate access	Needs to gain access
-----------------------	----------------------

Harder to detect	Easier to detect
------------------	------------------

15 Common SOC L1 Interview Questions & Answers

Q1. How do you detect insider threats?

Answer:

By monitoring abnormal user behavior, unusual data access patterns, and unauthorized activities.

Q2. What logs do you analyze?

Answer:

Authentication logs, file access logs, endpoint logs, and cloud activity logs.

Q3. What is your first action?

Answer:

Triage the alert, validate user activity legitimacy, and assess data impact.

Q4. When do you escalate?

Answer:

When sensitive data is involved or malicious intent is suspected.

Q5. How do you prevent insider threats?

Answer:

Using least privilege access, DLP solutions, user monitoring, and security awareness training.

Interview Closing Statement (USE THIS)

Best Answer:

“As a SOC L1 analyst, my role in insider threat incidents is to detect abnormal user activities, validate suspicious behavior, contain unauthorized access, document findings, and escalate when sensitive data or malicious intent is identified.”

How to Study This for Interview

-  Understand types of insiders
-  Focus on user behavior monitoring
-  Practice one real scenario

Use SOC keywords:

- UBA
- Least privilege
- Data access anomaly
- Containment

- Escalation
-

PRIVILEGE ESCALATION – COMPLETE SOC L1 INTERVIEW GUIDE

1 What is Privilege Escalation?

Privilege Escalation is an attack where a user or attacker:

👉 Gains **higher access rights** than they are authorized to have

Example:

- Normal user → Admin access
 - Admin → Domain Admin
-

 **SOC View:**

Any **unauthorized elevation of permissions, suspicious admin activity, or abnormal access rights changes** is treated as potential privilege escalation.

2 Why Privilege Escalation Matters in SOC?

Because once attackers gain higher privileges, they can:

-  Control systems
-  Disable security tools
-  Steal sensitive data
-  Move across the network

It is a **critical stage in most cyber attacks**.

3 Types of Privilege Escalation (INTERVIEW MUST)

◆ 1. Vertical Privilege Escalation (Most Common)

User gains higher-level permissions.

Example:

Normal user becomes Administrator.

◆ 2. Horizontal Privilege Escalation

User accesses another user's account with same privilege level.

Example:

Employee accessing another employee's data.

◆ 3. Local Privilege Escalation

Attacker escalates privileges on a single system.

Example:

Exploiting OS vulnerability to gain admin rights.

◆ 4. Domain Privilege Escalation (VERY IMPORTANT)

Attacker gains **Domain Admin access** in Active Directory.

This is extremely critical.

4 Common Privilege Escalation Methods

Method	Example
Exploiting Vulnerabilities	Unpatched OS flaws
Password Cracking	Admin password brute force
Credential Dumping	Using Mimikatz
Misconfigured Permissions	Weak access controls
Token Impersonation	Stealing session tokens

5 Real SOC Scenario (INTERVIEW GOLD)

Scenario:

SIEM alert shows:

- Normal user account added to “Domain Admins” group
 - Change occurred at midnight
 - Activity from unusual IP
-

SOC L1 Thinking:

- Unauthorized privilege change
 - Suspicious timing
 - ➡ Possible privilege escalation
-

6 Indicators of Privilege Escalation (IOCs)

SOC L1 watches for:

Account Indicators

- User added to admin groups
 - Sudden permission changes
 - Unauthorized role assignments
-

System Indicators

- Execution of privilege escalation tools
- Suspicious PowerShell commands

- New admin account creation
-



Behavioral Indicators

- Access to restricted resources
 - Abnormal admin activities
-

7 Logs SOC L1 Must Check

◆ Authentication Logs

- Windows Event Logs (4624, 4672)
 - AD login logs
-

◆ Account Management Logs

- Event ID 4728 → User added to group
 - Event ID 4720 → New account created
-

◆ Endpoint Logs

- EDR alerts
- Process execution logs

8 SOC L1 Detection in SIEM (Conceptual)

SOC L1 looks for:

- Privilege changes outside business hours
- Unauthorized admin group membership
- Suspicious credential usage

Example Rule:

“User added to Domain Admin group outside business hours”

9 SOC L1 Response – Step by Step

Step 1: Alert Triage

Identify:

- User account involved
 - Privilege change details
 - Time and source IP
-

Step 2: Validation

Check:

- Was change authorized?
 - Admin activity logs
 - User role and job function
-

Step 3: Containment

Actions:

- Remove unauthorized privileges
 - Disable compromised account
 - Block suspicious IP
-

Step 4: Scope Analysis

Check:

- Other accounts affected?
 - Lateral movement signs?
 - Credential compromise?
-

Step 5: Escalation

Escalate if:

- Domain Admin access gained
- Critical systems affected
- Signs of active attack

10 If Privilege Escalation is Successful – Risks

- Full system control
 - Data theft
 - Security tool disablement
 - Lateral movement
 - Persistence establishment
-

11 Post-Incident Actions

- Reset compromised credentials
 - Review access permissions
 - Patch vulnerabilities
 - Strengthen monitoring
-

12 Prevention Measures (INTERVIEW FAVORITE)

Access Control

- Least privilege principle
 - Role-based access control (RBAC)
-

Security Monitoring

- SIEM alerts
 - Privileged account monitoring
-

Credential Protection

- Strong password policies
 - MFA implementation
-

Patch Management

- Regular system updates
-

Documentation (SOC L1 Responsibility)

SOC L1 records:

- Timeline
- Accounts involved
- Privilege changes
- Actions taken

- Escalation notes
-



Privilege Escalation vs Lateral Movement (COMMON INTERVIEW)

Privilege Escalation

Gain higher access

Focus on permissions

Lateral Movement

Move between systems

Focus on network spread



Common SOC L1 Interview Questions & Answers

Q1. How do you detect privilege escalation?

Answer:

By monitoring unauthorized privilege changes, admin group additions, and abnormal admin activities.

Q2. What logs do you analyze?

Answer:

Authentication logs, account management logs, AD logs, and EDR alerts.

Q3. What is your first action?

Answer:

Triage the alert, verify authorization, and contain unauthorized access.

Q4. When do you escalate?

Answer:

When critical privileges like Domain Admin are compromised.

Q5. How do you prevent privilege escalation?

Answer:

Least privilege access, MFA, patch management, and monitoring privileged accounts.

16 Interview Closing Statement (USE THIS)

 **Best Answer:**

“As a SOC L1 analyst, my role in privilege escalation incidents is to detect unauthorized access changes, validate alerts, contain compromised

accounts, document findings, and escalate when critical privileges are involved.”

How to Study This for Interview

- ✓ Understand privilege types
- ✓ Remember key Windows Event IDs
- ✓ Practice one escalation scenario

Use SOC keywords:

- Least privilege
 - Admin group changes
 - Credential compromise
 - Containment
 - Escalation
-

LATERAL MOVEMENT – IN-DEPTH SOC L1 INTERVIEW GUIDE

1 What is Lateral Movement? (Core Concept)

Lateral Movement is when an attacker:

- 👉 Moves from one compromised system to other systems inside the network
- 👉 Uses stolen credentials or tools to spread

Goal:

- Find valuable data
 - Reach Domain Controller
 - Gain full network control
-

Simple Understanding

Think of it like:

An intruder enters one room in a building, then secretly moves room-to-room to reach the main control room.

SOC View (Very Important)

SOC L1 treats lateral movement as:

-  **Post-compromise activity**
 -  Indicator attacker is already inside network
 -  High severity alert
-

Why Lateral Movement is CRITICAL in SOC?

Because it indicates:

-  Attack has progressed beyond initial access
-  Organization is already compromised
-  Risk of full domain takeover

If not stopped:

- Domain admin compromise
 - Data exfiltration
 - Ransomware deployment
-

③ Where Lateral Movement Happens in Attack Lifecycle

According to **MITRE ATT&CK**:

Initial Access → Persistence → Privilege Escalation → **LATERAL MOVEMENT** → **Data Theft / Ransomware**

👉 It is a **middle-to-late stage attack**

④ Common Lateral Movement Techniques (INTERVIEW MUST)

♦ 1. Pass-the-Hash (VERY COMMON)

Attacker steals password hash and logs in without knowing password.

Used in Windows networks.

♦ 2. Pass-the-Ticket

Uses stolen Kerberos tickets.

Very common in Active Directory attacks.

◆ 3. Remote Desktop Protocol (RDP)

Attacker uses stolen credentials to connect to other machines.

◆ 4. SMB / Admin Shares

Using file shares like:

C\$ ADMIN\$ IPC\$

◆ 5. PsExec (VERY IMPORTANT)

Windows tool used by attackers to execute commands remotely.

Very common SOC alert.

◆ 6. WMI (Windows Management Instrumentation)

Used to run remote commands stealthily.

5 Real SOC Scenario (INTERVIEW GOLD)

Scenario:

EDR alert shows:

- User logged into 10 machines in 20 minutes
 - Used admin credentials
 - Login from unusual system
-

SOC L1 Thinking Process:

Questions SOC L1 asks:

- Why is one user logging into many systems?
- Is this normal admin behavior?
- Is it automated?

 Possible Lateral Movement

Indicators of Lateral Movement (IOCs)

This section is **very important for interviews**.

Authentication Indicators

- Multiple logins across systems quickly
 - Logins using admin accounts
 - Login from unusual host
-



System Indicators

- Remote command execution
 - Suspicious processes (PsExec, WMIC)
 - Credential dumping tools
-



Network Indicators

- Internal network scanning
 - SMB connections between hosts
 - RDP sessions internally
-

7 MOST IMPORTANT WINDOWS EVENT IDS

SOC L1 MUST REMEMBER THESE:

◆ Event ID 4624

Successful login

Important fields:

- Logon Type 3 → Network login
 - Logon Type 10 → RDP login
-

◆ Event ID 4648

Explicit credential usage.

Strong indicator of lateral movement.

◆ **Event ID 4672**

Admin privileges assigned.

◆ **Event ID 4688**

New process creation (PsExec/WMI).

8 Logs SOC L1 Must Analyze

◆ **Endpoint Logs**

- EDR alerts
 - Process execution logs
-

◆ **Authentication Logs**

- Windows Security Logs
 - AD logs
-

◆ Network Logs

- Firewall logs
 - NetFlow logs
 - IDS alerts
-

9 SOC L1 Detection Logic in SIEM

SOC L1 uses correlation rules like:

Example Use Cases:

- ✓ One user → multiple host logins
 - ✓ Admin login outside business hours
 - ✓ Remote command execution detected
-

Sample Detection Rule:

“User logs into more than 5 hosts within 10 minutes”

10 SOC L1 Investigation – Step by Step

This is **VERY IMPORTANT** for interview answers.

● Step 1: Alert Triage

Check:

- User account involved
 - Number of systems accessed
 - Timeframe
-

Step 2: Validation

Ask:

- Is this a system admin activity?
 - Is login behavior normal?
 - Is host trusted?
-

Step 3: Containment Actions

SOC L1 may:

- Disable compromised account
 - Isolate affected systems
 - Block suspicious connections
-

Step 4: Scope Analysis

Check:

- How many systems affected?
- Was domain controller accessed?

- Signs of privilege escalation?
-

Step 5: Escalation Criteria

Escalate immediately if:

-  Domain admin involved
 -  Multiple systems compromised
 -  Credential dumping detected
-

Real Attack Example Flow (Interview Favorite)

Step-by-Step:

1. Attacker phishes user
2. Gains initial access
3. Dumps credentials using Mimikatz
4. Uses PsExec to access other systems
5. Reaches Domain Controller
6. Deploys ransomware

 This is a classic lateral movement chain.

Risks of Lateral Movement

- Full network compromise
- Data exfiltration

- Privilege escalation
 - Ransomware spread
-

Prevention Measures (Interview Favorite)

Access Controls

- Least privilege principle
 - Limit admin accounts
-

Credential Security

- MFA enforcement
 - Password rotation
-

Network Security

- Network segmentation
 - Block SMB where not needed
-

Monitoring

- EDR behavioral detection

- SIEM correlation rules
-

14 Lateral Movement vs Privilege Escalation

Lateral Movement		Privilege Escalation	
Moving systems	between	Gaining access	higher
Uses privileges	existing	Increases privileges	

15 Most Asked SOC L1 Interview Questions

Q1. How do you detect lateral movement?

Answer:

By monitoring multiple logins across systems, remote command execution, admin credential usage, and abnormal authentication patterns.

Q2. Which logs are most important?

Answer:

Windows authentication logs, process logs, EDR alerts, and network traffic logs.

Q3. What tools indicate lateral movement?

Answer:

PsExec, WMI, RDP, SMB shares, and credential dumping tools.

Q4. What is your first response?

Answer:

Triage the alert, verify legitimacy, and contain compromised accounts or systems.

Q5. Why is lateral movement dangerous?

Answer:

Because it allows attackers to spread across network and gain full control.

Interview Closing Statement (HIGH IMPACT)

Use this exact wording:

“As a SOC L1 analyst, I monitor authentication anomalies, remote execution activities, and credential misuse to detect lateral movement early. My role is to validate alerts, contain compromised accounts or systems, and escalate quickly to prevent domain-wide compromise.”

How to Study This (Best Method)

Focus on remembering:

- ✓ Event IDs: 4624, 4648, 4672, 4688
 - ✓ Tools: PsExec, WMI, RDP
 - ✓ Pattern: One user → many systems
-

Got it 👍

You want **Port Scanning / Reconnaissance** in the **EXACT SAME FORMAT** as your Brute Force notes so you can memorize for SOC L1 interview.

Here it is 👉

PORT SCANNING / RECONNAISSANCE **– COMPLETE SOC L1 INTERVIEW GUIDE**

What is Port Scanning / Reconnaissance?

A port scanning attack is a reconnaissance activity where an attacker probes multiple ports on a system to identify open services and potential entry points.

It is usually automated and performed before launching further attacks.

SOC View:

Any abnormal pattern of repeated connection attempts to multiple ports from the same source within a short time is treated as potential reconnaissance.

2 Why Port Scanning Matters in SOC?

Because:

- It is usually the **first stage of cyber attacks**
- It helps attackers identify vulnerabilities
- If ignored, it can lead to:

👉 Exploitation attempts

👉 Brute force attacks

👉 Malware deployment

👉 Data breaches

3 Common Services Targeted

Service	Port	Why Targeted
SSH	22	Remote Linux access
RDP	3389	Windows remote access
SMB	445	Lateral movement

HTTP	80	Web vulnerabilities
HTTPS	443	Secure web apps
FTP	21	File transfer exploitation

4 Types of Port Scanning (Interview MUST)

♦ 1. TCP Connect Scan

Attempts full connection handshake.

Very noisy and easy to detect.

♦ 2. SYN Scan (Most Common)

Half-open connections only.

Stealthy and widely used by attackers.

♦ 3. UDP Scan

Scans UDP services.

Harder to detect.

♦ 4. Stealth Scans

Designed to evade detection.

Examples:

- FIN scan
 - NULL scan
 - Xmas scan
-

5 Real SOC Scenario (Interview Gold)

Scenario:

SIEM generates alert:

“Single external IP attempted connections to 300 different ports on a server within 3 minutes.”

SOC L1 Thinking:

External IP

Multiple ports

Short timeframe

➡ Possible reconnaissance / port scanning activity.

6 Indicators of Port Scanning (IOCs)

SOC L1 watches for:

- High number of connection attempts
- Same IP targeting many ports

- Rapid connection attempts
 - Many connection failures
 - No authentication activity
-

7 Logs SOC L1 Must Check

♦ Network Logs

Firewall logs
IDS/IPS alerts
NetFlow logs

♦ System Logs

Server connection logs
Application logs

♦ SIEM Alerts

Correlation rules detecting:

- Multiple connection attempts
 - Port scan signatures
-

8 SOC L1 Detection in SIEM (Conceptual)

SOC L1 looks for:

- Same source IP
- Multiple destination ports
- High connection frequency

Example Logic:

“More than 50 connection attempts to different ports within 5 minutes.”

9 SOC L1 Response – Step by Step

Step 1: Alert Triage

Identify:

Source IP

Target system

Number of ports scanned

Timeframe

Step 2: Validation

Check:

Is IP internal or external?

Is it vulnerability scanner?

Check IP reputation using:

VirusTotal
AbuseIPDB
Cisco Talos

Step 3: Containment

Block IP at firewall (if malicious)
Notify network team

Step 4: Scope Analysis

Check:

Other systems targeted?
Any exploitation attempts after scan?

Step 5: Escalation

Escalate if:

Exploitation attempts detected
Critical assets targeted
Persistent scanning observed

If Port Scanning is Successful – Risks

Discovery of open services

Identification of vulnerabilities

Preparation for attacks such as:

Brute force

Exploitation

Lateral movement

11 Post-Incident Actions

Block malicious IPs

Review firewall rules

Close unnecessary ports

Monitor targeted systems

12 Prevention Measures (Interview Favorite)

Network Security

Close unused ports

Enable firewall filtering

Network segmentation

Detection Controls

Deploy IDS/IPS
Rate limiting rules
Enable logging

Security Monitoring

Continuous SIEM monitoring
Threat intelligence integration

Documentation (SOC L1 Responsibility)

SOC L1 documents:

Timeline of scanning
Source IP details
Target systems
Actions taken
Escalation notes

Port Scanning vs Brute Force (Asked Often)

Port Scanning	Brute Force
Targets ports/services	Targets authentication

Pre-attack stage	Active attack stage	
No login attempts	Multiple attempts	login
Recon activity	Access attempt	

15 Common SOC L1 Interview Questions & Answers

Q1. How do you identify port scanning?

Answer:

By observing repeated connection attempts from the same source IP targeting multiple ports within a short time.

Q2. What logs do you analyze?

Answer:

Firewall logs, IDS alerts, NetFlow logs, and SIEM correlation alerts.

Q3. How do you differentiate false positives?

Answer:

By verifying whether the source IP belongs to internal vulnerability scanners or legitimate network tools.

Q4. When do you escalate?

Answer:

If scanning is followed by exploitation attempts or targets critical systems.

Q5. What MITRE ATT&CK technique applies?

Answer:

Active Scanning — T1595.

Interview Closing Statement (Use This)

“As a SOC L1 analyst, my role is to detect reconnaissance activities such as port scanning, validate alerts, assess risk, contain potential threats, document findings, and escalate when necessary to prevent further attacks.”

How to Study This for Interview

Memorize the investigation flow

Understand recon → attack timeline

Practice explaining one real scenario

Use SOC keywords:

Triage

Validation

Containment

Escalation

HOW TO INVESTIGATE ANY SIEM ALERT — STEP-BY-STEP (SOC L1 GUIDE)

THE GOLDEN RULE (MEMORIZE THIS FIRST)

Every SIEM investigation follows this flow:

Triage → Validate → Investigate → Contain → Escalate → Document

If you remember **ONLY** this line, you can answer any interview question.

STEP 1: ALERT TRIAGE (Understand the Alert)

Goal:

Understand **what happened**.

What SOC L1 Checks First:

Alert Name

Example:

- Brute Force Detected
- Malware Alert
- Suspicious Login

Severity Level

- Low → Monitor
- Medium → Investigate
- High → Immediate action

Timestamp

When did it happen?

Affected Asset

Which:

- User?
- IP?
- Server?

- Endpoint?
-

Interview Line:

“First, I perform alert triage by reviewing the alert type, severity, timestamp, and affected assets.”

STEP 2: VALIDATION (Check if it's Real or False Positive)

Goal:

Confirm if the alert is **legitimate threat or normal activity**.

What SOC L1 Checks:

♦ Source IP Reputation

Use tools:

- VirusTotal
- AbuseIPDB

- Cisco Talos

Check:

Is IP malicious?

♦ Internal vs External Source

- Internal IP → Could be normal activity
 - External IP → Higher risk
-

♦ User Behavior

Ask:

Is user expected to perform this activity?

Example:

Admin logging at midnight → suspicious.

♦ Business Context

Check:

- Is it maintenance time?
- Is it vulnerability scan?

Interview Line:

“I validate the alert by checking IP reputation, user behavior, and business context to determine whether it is a false positive.”

STEP 3: INVESTIGATION (Deep Analysis)

Goal:

Understand **scope and impact**.

SOC L1 Checks:

1 Check Related Logs

Look at:

- Authentication logs
- Firewall logs
- Endpoint logs
- Network logs

2 Identify Pattern

Ask:

- Is it repeated activity?
- Is it targeting multiple systems?
- Is it ongoing?

3 Look for Success Indicators

Example:

Brute Force case:

Failed logins → then successful login.

This is VERY critical.

4 Determine Scope

Check:

- Other users affected?
- Other systems targeted?

Interview Line:

“During investigation, I analyze related logs, identify patterns, check for successful compromise, and determine the scope of the incident.”

STEP 4: CONTAINMENT (Stop the Threat)

Goal:

Prevent further damage.

Common SOC L1 Actions:

◆ Block Malicious IP

At firewall.

◆ Disable User Account

If compromised.

◆ Isolate Endpoint

If malware detected.

♦ **Force Password Reset**

For suspicious login.

 Interview Line:

“If the threat is confirmed, I take containment actions such as blocking IPs, disabling accounts, or isolating affected systems.”

STEP 5: ESCALATION (When SOC L1 Hands Over)

 Goal:

Send serious incidents to SOC L2.

Escalate When:

- Account compromise confirmed
- Malware infection detected
- Privileged account involved
- Lateral movement suspected

- Data exfiltration observed
-

Interview Line:

“I escalate the incident to SOC L2 when there is confirmed compromise, high risk impact, or need for deeper forensic analysis.”

STEP 6: DOCUMENTATION (VERY IMPORTANT)

SOC L1 MUST document everything.

Include:

- Timeline of events
 - Source & destination IPs
 - Affected users/systems
 - Actions taken
 - Escalation details
-

Interview Line:

“Finally, I document the entire investigation including timeline, findings, actions taken, and escalation notes.”

★ COMPLETE INVESTIGATION FLOW (MEMORY FORMULA)

Remember this:

👉 **T V I C E D**

T — Triage

V — Validate

I — Investigate

C — Contain

E — Escalate

D — Document

This is a **top interview trick**.

🔥 REAL EXAMPLE (Brute Force Alert)

Alert:

Multiple failed login attempts detected.

SOC L1 Process:

- 1 Triage → Check alert details
 - 2 Validate → Check IP reputation
 - 3 Investigate → Analyze login logs
 - 4 Contain → Block IP & reset password
 - 5 Escalate → If login succeeded
 - 6 Document → Write incident report
-



MOST COMMON INTERVIEW QUESTION

? “How do you investigate a SIEM alert?”

✓ PERFECT ANSWER:

“I follow a structured approach starting with alert triage, then validating whether it is a false positive, performing detailed log analysis to understand the scope, taking containment actions if necessary, escalating to higher teams when required, and finally documenting the entire incident.”